Threat and Risk Assessment: Summary

Provincial health network (fictional) · Assessed 2026-10-28 · Prepared by Manthan Ray · github.com/manthanray03/healthcare-network-risk-assessment

The network design already cuts total risk by about 25%, mostly through VLAN segmentation, least-privilege ACLs and encrypted, SSH-only management. Even so, 13 of the 17 active risks are still High or Critical, so the design isn't ready to carry patient data yet. The one Critical risk is vendor remote access to medical devices. If all 36 remediation actions are completed, no risk stays above Medium.

20
risks assessed (17 active, 2 accepted, 1 closed)

13 of 17
active risks rated High or Critical

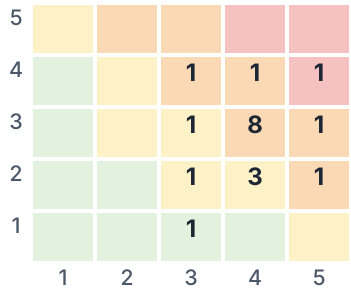
5
of 36 remediation actions overdue

25% → 65%
total risk reduced now, and once every action is done

Scope

A data centre, two hospitals and five rural clinics joined by a provincial WAN, with an IPsec backup path for the clinics. Six VLANs separate clinical, admin, VoIP, guest, medical-device and management traffic. Controls already in place: least-privilege ACLs, a pfSense edge firewall, IPsec (AES-256/SHA-256), SSH-only management, SNMPv3, central syslog, and dual cores with HSRP at the hospitals. One cloud PACS and teleradiology vendor was assessed separately. The EHR application code and medical device internals are out of scope.

Residual risk heatmap



Likelihood up, impact across. Open, in-treatment and accepted risks. Bands: Low 1-4, Medium 5-9, High 10-16, Critical 20-25.

Key risk indicators

Indicator	Value	Target
Critical risks open	1	0
High and critical risks open	13	3 or fewer
Overdue remediation actions	5	0
Actions completed on time	60%	90% or more
Risks past their 90-day review	2	0

Generated by report.py from the risk register on 2026-10-28.

Top 5 risks

ID	Risk	Inherent	Residual	Target	Main recommendation
R12	Vendor remote support access to medical devices is uncontrolled	20	20	6	Jump host with per-session approval, MFA and recording; contract terms (both overdue)
R10	Phishing leads to a compromised staff account	20	16	6	Enforce MFA for all staff; phishing training and quarterly simulations
R01	Ransomware spreads from an admin workstation to clinical servers	20	15	8	EDR on all endpoints; immutable offline EHR backups and a timed restore test
R02	Unpatched medical devices on VLAN 50 are exploited	20	12	8	Device inventory (overdue); vendor patch windows; alert on new outbound traffic
R07	Intrusion goes unnoticed because logs are not reviewed	16	12	6	Alert rules for failed logins, config changes and clinical firewall denies

Recommendations by priority

Next 30 days (by the end of November 2026)

1. Control vendor remote access to medical devices (A23, A24). This is the only Critical risk.
2. Enforce MFA for all staff and finish phishing training (A20, A21).
3. Finish the medical device inventory (A04) and start monthly vulnerability scans (A35).
4. Move network device logins to individual accounts through RADIUS (A09).

Next 90 days (by the end of January 2027)

5. Roll out EDR (A01) and the syslog alert rules (A13).
6. Quarterly EHR access reviews (A18); confirm TLS on every clinical app crossing the WAN (A16).
7. Canadian data residency and a Canadian-region SOC 2 report from the teleradiology vendor (A25, A26).
8. Change tickets plus nightly comparison against the approved baseline (A30, A31); encrypt the backup share (A12).

Within 6 months (by the end of April 2027)

9. Immutable backups and a restore test (A02, A03), a second domain controller (A32) and a second firewall (A22).
10. A network incident playbook and a tabletop exercise with clinical managers (A33, A34).
11. Lockable racks at the clinics (A29); TLS or IPsec for the legacy HL7 feed (A17).

Vendor assessment

Prairie Imaging Cloud (fictional), cloud PACS and teleradiology: **73.5%** on a 15-question weighted questionnaire, rated High risk.

Must-have	Result
Data stored only in Canada	No: DR replica in US-East
SOC 2 / ISO 27001 for our region	Partial: US-East only
Breach notice within 24 hours	Partial: "without undue delay"
Encryption, TLS 1.2+, staff MFA	Yes

Recommendation: don't approve until data residency is fixed in the contract.

Accepted risks

ID	Risk	Residual
R04	Clinic loses its primary WAN link (IPsec backup path keeps clinics connected)	6
R18	Management traffic read or altered (SNMPv3, VLAN 99, SSH only)	3

Both accepted by the Director of IT Operations. R18's review is overdue.

HIPA safeguards (section 16)

Safeguard	Risks	Main gap
Administrative	R09, R10, R12, R13, R16, R19	No access reviews, no awareness training, weak vendor terms, no incident playbook
Technical	R01-R08, R11, R17, R18, R20	MFA, EDR, offline backups, log alerting, vulnerability scanning
Physical	R14, R15	Clinic equipment sits in shared storage rooms

Method

Each risk was scored three times (inherent, residual today, target after actions) as likelihood x impact on a 5 × 5 matrix and mapped to NIST CSF 2.0 and ISO/IEC 27001:2022 Annex A. A Python and SQL tool checks the register for data errors, calculates the KRIs and builds the dashboard; GitHub Actions runs those checks on every change.

Learning project. The organization, vendor, people and findings are fictional; owners are job roles. Likelihood is a judgement based on the design documents; no penetration test or scan was run. This is not a legal opinion on HIPA compliance. Full report, register and code: github.com/manthanray03/healthcare-network-risk-assessment